ANKARA ÜNİVERSİTESİ

MÜHENDİSLİK FAKÜLTESİ

BİLGİSAYAR MÜHENDİSLİĞİ BÖLÜMÜ

BLM4522

Ağ Tabanlı Paralel Dağıtım Sistemleri

Proje 3: Veritabanı Güvenliği ve Erişim Kontrolü

Hazırlayan: Hüseyin Şen

Numara: 22290282

https://github.com/huseyinnsenn/BLM4522-Ag-Tabanli-Paralel-Dagitim-Sistemi.git

ÖZET

Bu çalışmada, Docker ortamında çalışan PostgreSQL 15 veritabanı üzerinde kapsamlı bir güvenlik mimarisi tasarlanmış ve uygulanmıştır. "En Az Ayrıcalık" (Principle of Least Privilege) prensibine dayalı rol tabanlı erişim kontrolü, pgcrypto eklentisi ile kolon bazlı veri şifreleme, uygulama katmanından gelebilecek SQL Injection saldırılarına karşı parametrik sorgu (Prepared Statements) koruması ve kullanıcı aktivitelerini izlemek amacıyla veritabanı seviyesinde Audit Logging işlemleri başarıyla test edilmiştir.

1. Projenin Amacı ve Kapsamı

Veritabanı güvenliği, modern dağıtık sistemlerin en kritik bileşenlerinden biridir. İçeriden gelebilecek yetkisiz erişimler veya dışarıdan sızmaya yönelik manipülasyonlar (Injection) veritabanı motoru seviyesinde engellenmelidir.

Bu projedeki hedefler şunlardır:

- Rol Tabanlı Erişim Kontrolü (RBAC) ile kısıtlı yetkiye sahip kullanıcı profilleri oluşturmak.
- Hassas verileri (kredi kartı bilgileri vb.) simetrik şifreleme algoritmalarıyla korunur hale getirmek.
- SQL Injection zafiyetlerini simüle etmek ve güvenli arama fonksiyonları ile bu saldırıları savuşturmak.
- Sistem üzerinde yapılan veri manipülasyonlarını (DML) izleyebilmek için Audit Log mekanizmasını devreye almak.

2. Erişim Yönetimi (Role-Based Access Control)

Sistemdeki verilere sadece okuma yetkisiyle erişmesi gereken roller için stajyer_raporcu adında kısıtlı bir kullanıcı oluşturulmuştur. Bu kullanıcıya yalnızca SELECT yetkisi tanımlanmıştır.

Test Sonucu: Bu kısıtlı kullanıcı ile sisteme bağlanıp DELETE FROM customer; komutu çalıştırıldığında, PostgreSQL motoru tarafından anında ERROR: permission denied for table customer hatası fırlatılmış ve yetkisiz veri silme girişimi başarıyla engellenmiştir.

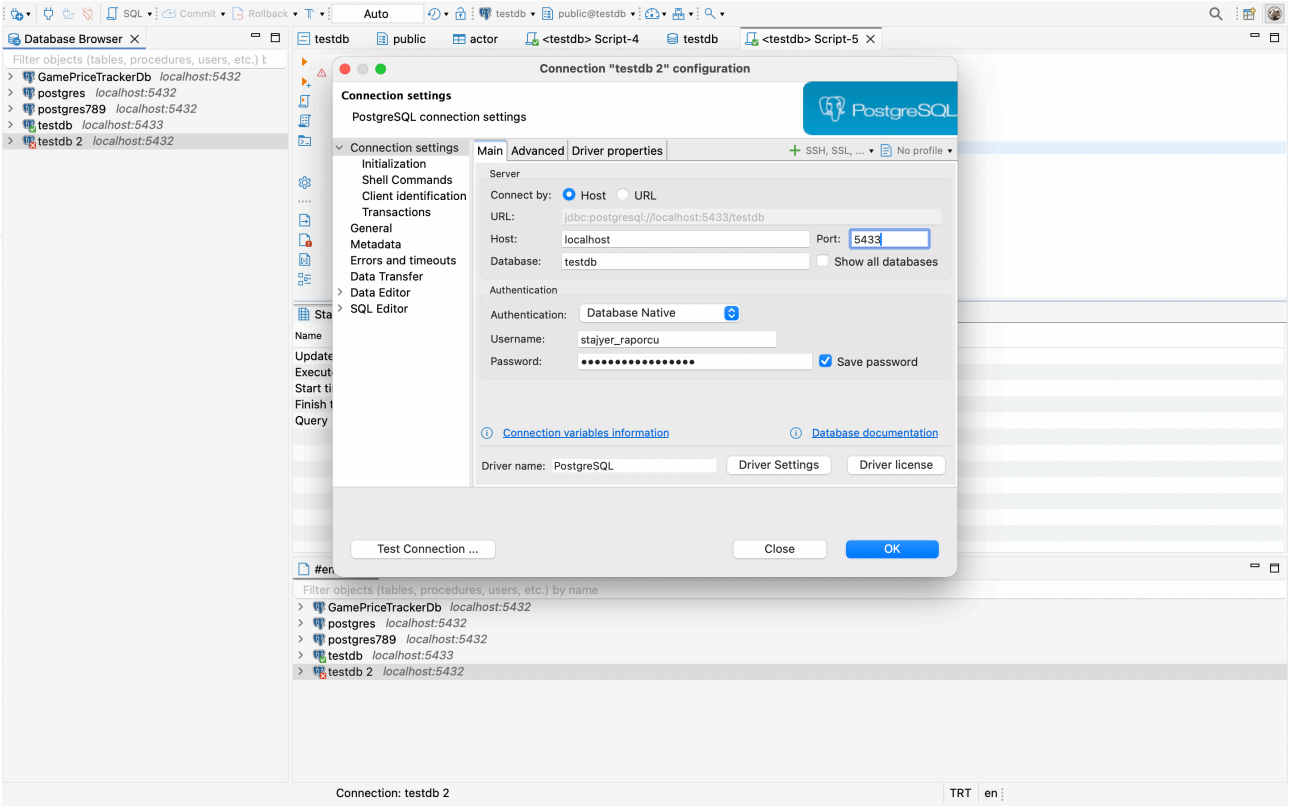
Yeni oluşturduğumuz user ile database’e bağlanıyoruz.

```sql
CREATE ROLE stajyer_raporcu WITH LOGIN PASSWORD 'GuvenliSifre2026!';

GRANT CONNECT ON DATABASE testdb TO stajyer_raporcu;

GRANT USAGE ON SCHEMA public TO stajyer_raporcu;

GRANT SELECT ON ALL TABLES IN SCHEMA public TO stajyer_raporcu;
```



3. Veri Şifreleme

Veritabanına doğrudan erişimi olan yetkili hesapların dahi hassas verileri düz metin (plain-text) olarak okumasını engellemek amacıyla pgcrypto eklentisi kullanılmıştır.

customer tablosuna gizli_kart_bilgisi adında binary (BYTEA) formatında yeni bir kolon eklenmiş ve veriler PGP_SYM_ENCRYPT fonksiyonu ile şifrelenmiştir:

customer 1

SELECT first_name, last_name, gizli_kart | Enter a SQL expression to filter re

	first_name	last_name	gizli_kart_bilgisi
1	Mary	Smith	Ã J fk ²dÒD : Ïl zÏ iEÈ²ó...

```sql
CREATE EXTENSION IF NOT EXISTS pgcrypto;


ALTER TABLE customer ADD COLUMN gizli_kart_bilgisi BYTEA;


UPDATE customer
SET gizli_kart_bilgisi = PGP_SYM_ENCRYPT('4532-1111-2222-3333', 'ProjeIcinGizliAnahtar')
WHERE customer_id = 1;


SELECT first_name, last_name, gizli_kart_bilgisi
FROM customer
WHERE customer_id = 1;
```

customer 1

SELECT first_name, last_name, PGP_SYM | Enter a SQL expression to filter re

Grid | Text

	first_name	last_name	cozulen_kart_bilgisi
1	Mary	Smith	4532-1111-2222-3333

Test Sonucu: Veri tabanına normal bir SELECT sorgusu atıldığında ilgili kolon okunamaz bir formatta dönmektedir. Veri, ancak uygulama katmanında doğru simetrik anahtar sağlanıp PGP_SYM_DECRYPT fonksiyonu kullanıldığında çözülebilmektedir.

4. SQL Injection Testleri

Kötü niyetli kullanıcıların arama parametreleri üzerinden sistemi manipüle etmesini engellemek için arka planda zafiyet barındıran ve güvenli olan iki farklı fonksiyon tasarlanmıştır.

Arama kutusuna ' OR '1'='1 şeklinde bir zafiyet enjekte edildiğinde:

- **Güvensiz Fonksiyonda:** Tırnaklar kırılmış ve tablodaki tüm müşteriler yetkisiz bir şekilde ekrana dökülmüştür.

Auto | testdb | public@testdb

public | actor | <testdb> Sc... | *<testdb 2>... | *<testdb> S...

```sql
SELECT * FROM guvensiz_arama('Jared'' OR ''1''=''1');
```

Results 1

SELECT * FROM guvensiz_arama('Jared'' Ente

	first_name	last_name
1	Jared	Ely
2	Patricia	Johnson
3	Linda	Williams
4	Barbara	Jones
5	Elizabeth	Brown
6	Jennifer	Davis
7	Maria	Miller

- **Güvenli Fonksiyonda (Prepared Statements):** WHERE first_name = $1 parametrik yapısı sayesinde gönderilen payload sadece düz bir metin olarak algılanmış ve sistem hiçbir veri sızdırmamıştır.

```
SELECT * FROM guvenli_arama('Jared'' OR ''1''=''1');
```

Results 1

SELECT * FROM guvenli_arama('Jared'' O Enter a

first_name	last_name

5. Audit Logları (Kullanıcı Aktivitelerini İzleme)

Sistemde meydana gelen tüm kritik veri değişikliklerini (INSERT, UPDATE, DELETE) anlık olarak kayıt altına almak için PostgreSQL konfigürasyonu güncellenmiştir.

```
ALTER DATABASE testdb SET log_statement = 'mod';
```

Bu ayarlama sayesinde, veritabanı üzerinde gerçekleşen her türlü DML (Data Manipulation Language) işlemi detaylı bir şekilde PostgreSQL log dosyalarına yazılmaya başlanmış, böylece olası bir siber olayda geriye dönük iz sürme kapasitesi oluşturulmuştur.

6. Genel Değerlendirme

Bu proje çalışmasında, günümüz dağıtık sistem mimarilerinde kritik bir öneme sahip olan "veritabanı seviyesinde güvenlik" kavramı uçtan uca ele alınmıştır. Sistem güvenliği yalnızca uygulama (backend) katmanının inisiyatifine bırakılmamış; "Derinlemesine Savunma" (Defense in Depth) prensibi benimsenerek doğrudan PostgreSQL veritabanı motoru üzerinde proaktif ve katı kurallarla inşa edilmiştir.

Gerçekleştirilen uygulamalar sonucunda elde edilen temel kazanımlar şunlardır:

- **Erişim Yönetimi ve Yetkilendirme:** Sistemdeki roller, "En Az Ayrıcalık" (Principle of Least Privilege) ilkesi doğrultusunda yapılandırılmış; kısıtlı kullanıcıların yetkisiz veri manipülasyonu (DML) operasyonları veritabanı motoru tarafından kaynağında engellenmiştir.

- **Veri Mahremiyeti (Data at Rest):** Kredi kartı gibi hassas verilerin düz metin (plain-text) olarak saklanması riski ortadan kaldırılmıştır. pgcrypto eklentisi kullanılarak simetrik şifreleme mekanizmaları devreye alınmış, böylece veritabanına en üst düzey yetkiyle erişilse dahi doğru anahtar olmadan verinin okunabilirliği imkânsız hale getirilmiştir.

- **Zafiyet Yönetimi:** Uygulama ve veritabanı arasındaki iletişimdeki en yaygın siber saldırı vektörlerinden olan SQL Injection zafiyetleri simüle edilmiştir. Parametrik sorgu (Prepared Statements) yapıları kullanılarak dışarıdan gelen girdilerin SQL komutu olarak işlenmesi engellenmiş ve veri ile komut ayrımı kesin çizgilerle belirlenmiştir.

- **İzlenebilirlik (Traceability):** Audit Log mekanizmaları devreye alınarak sistem üzerinde gerçekleşen tüm kritik değişiklikler kayıt altına alınmıştır. Bu sayede olası bir güvenlik olayında geriye dönük iz sürme ve hesap verilebilirlik (accountability) standartları karşılanmıştır.

Sonuç olarak, bu projede kısıtlı yetkilendirme, simetrik kriptografi, parametrik sorgular ve izleme mekanizmaları bir bütün olarak entegre edilmiş; dış saldırılara karşı korunaklı, iç tehditlere karşı ise şeffaf ve dirençli bir modern veritabanı güvenlik altyapısı başarıyla tasarlanmıştır.